

VULNERABILITY ANALYSIS

ASSESSMENT FINDINGS REPORT

Target: Metasploitable 2

Vulnerability Analysis (IKB21403) – Week 10 Assignment
UniKL MIIT
Date: 7 June 2026

Contents

1. Executive Summary	3
Network Attack Path	3
2. Scope & Methodology	4
2.1 Environment Verification	4
2.2 Scanning Tools	5
2.3 Service Discovery (Nmap)	5
3. Findings Summary	7
4. Detailed Findings	8
F-01: vsftpd 2.3.4 Backdoor Command Execution (Critical)	8
Description	8
Impact	8
Evidence	8
False Positive Justification	9
Remediation	9
F-02: UnrealIRCD 3.2.8.1 Backdoor Command Execution (Critical)	10
Description	10
Impact	10
Evidence	10
False Positive Justification	11
Remediation	11
F-03: Samba "username map script" Command Execution (Critical)	12
Description	12
Impact	12
Evidence	12
False Positive Justification	12
Remediation	12
F-04: Java RMI Registry Insecure Default – Remote Code Execution (Critical)	14
Description	14
Impact	14
Evidence	14
False Positive Justification	14
Remediation	14
F-05: OpenSSL CCS Injection (Man-in-the-Middle) (High)	16
Description	16
Impact	16
Evidence	16
False Positive Justification	16
Remediation	17
5. Remediation Summary & Priorities	18
5.1 Why CVSS Is Not the Only Factor	18
6. References	19

1. Executive Summary

This report presents the results of a vulnerability analysis performed against the Metasploitable 2 target host (192.168.56.103). The objective was to discover, classify, validate, and prioritise vulnerabilities present on the system, then recommend remediation in line with industry best practice (NIST SP 800-115 and the OWASP Testing Guide).

Overall Risk Level: **CRITICAL**

Vulnerabilities reported: **5 (4 Critical, 1 High)**

Biggest concern: The host exposes multiple unauthenticated remote-code-execution paths that grant root access with trivial effort. The vsftpd 2.3.4 service contains a confirmed backdoor that was validated during testing to obtain a root shell (uid=0). Any attacker with network access to the host can fully compromise the system, read or destroy all data, and use it to pivot deeper into the network. Because working public exploits exist for every Critical finding, the realistic time-to-compromise is minutes.

Network Attack Path

A typical compromise scenario against this host requires no credentials and follows a short chain:

Attacker (Kali Linux) → TCP/21 vsftpd 2.3.4 backdoor → **root shell (uid=0)** → full host control
→ data exfiltration / lateral movement

Alternative entry points (Samba TCP/139–445, UnrealIRCd TCP/6667, Java RMI TCP/1099) reach the same outcome – unauthenticated code execution – providing the attacker with several redundant ways to gain root.

2. Scope & Methodology

Assessment Type	Internal, network-level vulnerability analysis
Scan Type	Unauthenticated (black-box, no credentials supplied)
Target (Victim)	192.168.56.103 – Metasploitable 2 (Linux)
Attacker Host	Kali Linux (VirtualBox VM, host-only network)
Tools Used	Nmap (-sV, -sC, NSE scripts: vuln, ftp-vsftpd-backdoor, irc-unrealircd-backdoor, smb-os-discovery, rmi-vuln-classloader, ssl-ccs-injection), CVE.org / NVD, CVSS v3.1 Calculator (FIRST)
Testing Date	7 June 2026 (single lab session)

Testing followed the standard phases of a vulnerability assessment: Planning (defining scope and target), Discovery (port, service, and version enumeration), Analysis (mapping services to known CVEs, CWEs, and CVSS scores, and manually validating findings), and Reporting (documenting confirmed issues with remediation).

2.1 Environment Verification

The attacker (Kali Linux) and victim (Metasploitable 2) were confirmed to reside on the same VirtualBox host-only subnet, with full IP connectivity verified by a ping test before scanning commenced.

```
(kali@kali) - [~/Desktop]
$ ifconfig
docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    ether da:72:d1:0d:82:cb txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 6 overruns 0 carrier 0 collisions 0

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fd17:625c:f037:2:4c3b:f3ab:82ad:6348 prefixlen 64 scopeid 0<0>
    <global>
        inet6 fe80::9ffc:a30b:c534:2cab prefixlen 64 scopeid 0<20<link>
        ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
        RX packets 7 bytes 2920 (2.8 KiB)
        RX errors 0 dropped 0 overruns 0 frame 0
        TX packets 28 bytes 4193 (4.0 KiB)
        TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 1 – Attacker (Kali Linux) network interface configuration

```

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:51:f3:6d
          inet addr:192.168.56.103 Bcast:192.168.56.255 Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe51:f36d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd010 Memory:f0000000-f0020000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$

```

Figure 2 – Victim (Metasploitable 2) interface: 192.168.56.103

```

(kali@kali) - [~/Desktop]
$ ping 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
 64 bytes from 192.168.56.103: icmp_seq=1 ttl=255 time=3.32 ms
 64 bytes from 192.168.56.103: icmp_seq=2 ttl=255 time=2.43 ms
 64 bytes from 192.168.56.103: icmp_seq=3 ttl=255 time=3.63 ms
 64 bytes from 192.168.56.103: icmp_seq=4 ttl=255 time=2.19 ms
 64 bytes from 192.168.56.103: icmp_seq=5 ttl=255 time=2.22 ms
 64 bytes from 192.168.56.103: icmp_seq=6 ttl=255 time=6.08 ms
 64 bytes from 192.168.56.103: icmp_seq=7 ttl=255 time=3.31 ms
 64 bytes from 192.168.56.103: icmp_seq=8 ttl=255 time=3.60 ms
 64 bytes from 192.168.56.103: icmp_seq=9 ttl=255 time=4.62 ms
 64 bytes from 192.168.56.103: icmp_seq=10 ttl=255 time=2.19 ms
 64 bytes from 192.168.56.103: icmp_seq=11 ttl=255 time=4.83 ms
 64 bytes from 192.168.56.103: icmp_seq=12 ttl=255 time=1.91 ms
^C
— 192.168.56.103 ping statistics —
 12 packets transmitted, 12 received, 0% packet loss, time 11453ms
 rtt min/avg/max/mdev = 1.909/3.360/6.084/1.235 ms

```

Figure 3 – Ping test confirming connectivity from Kali to Metasploitable 2

2.2 Scanning Tools

Nmap was the primary tool used for service discovery, version detection, and script-based vulnerability detection. Multiple Nmap NSE scripts were applied to confirm specific vulnerabilities against identified services.

2.3 Service Discovery (Nmap)

A full service/version scan (nmap -sV 192.168.56.103) enumerated the open ports and running service versions used as the basis for analysis, followed by a fast scan (nmap -F -sV) for verification.

```
(kali@kali)~[~/Desktop]
$ nmap -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:34 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0089s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: SWORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1009/tcp  open  java-rmi       GNU Classpath gmicregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.81 seconds
```

Figure 4 – Nmap service/version scan (-sV) – full port enumeration on 192.168.56.103

```
(kali@kali)~[~/Desktop]
$ nmap -F -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:35 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0096s latency).
Not shown: 82 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login?         login?
514/tcp   open  shell          Netkit rshd
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.25 seconds
```

Figure 5 – Nmap fast scan (-F -sV) confirming key services and versions

3. Findings Summary

Severity breakdown: **Critical 4** | **High 1** | Moderate 0 | Low 0

ID	Vulnerability	CVE	CVSS	Severity	Port
F-01	vsftpd 2.3.4 Backdoor Command Execution	CVE-2011-2523	9.8	Critical	21
F-02	UnrealIRCd 3.2.8.1 Backdoor Command Execution	CVE-2010-2075	9.8	Critical	6667
F-03	Samba "username map script" Command Execution	CVE-2007-2447	9.8	Critical	139/445
F-04	Java RMI Registry Insecure Default – RCE	N/A	9.8	Critical	1099
F-05	OpenSSL CCS Injection (MITM)	CVE-2014-0224	7.4	High	5432

Note on CVSS: For older CVEs (F-02, F-03) the NVD database publishes only a legacy CVSS v2 base score (UnrealIRCd 7.5, Samba 6.0). However, both are unauthenticated remote command execution leading to root. Re-scored under CVSS v3.1 with vector AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, each yields 9.8 (Critical). This illustrates that a published score can understate the real risk – the analyst must re-evaluate in context.

4. Detailed Findings

F-01: vsftpd 2.3.4 Backdoor Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2011-2523
CWE	CWE-78 – OS Command Injection
CVSS v3.1 Score	9.8 (Critical)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.103) – FTP / TCP 21
Tools Used	Nmap NSE (ftp-vsftpd-backdoor, vuln script)
False Positive?	No – True Positive

Description

The FTP service is running vsftpd 2.3.4, a version whose source archive was tampered to include a malicious backdoor. When a username containing the characters ":" is supplied to the FTP service, the daemon opens a command shell on TCP port 6200, allowing an unauthenticated attacker to execute operating-system commands as root.

Impact

Exploitation grants complete remote control of the host as the root user with no credentials and no user interaction. An attacker can read, modify, or destroy any data on the system, install persistence mechanisms, and pivot to other hosts. This is the highest-impact finding on the target.

Evidence

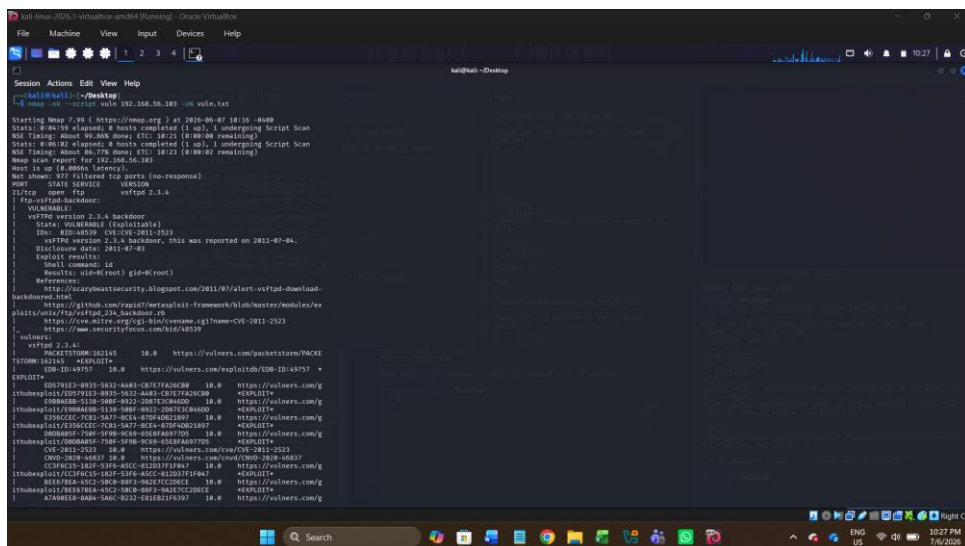


Figure 6 – NSE vuln script confirms vsftpd 2.3.4 backdoor as VULNERABLE (Exploitable); uid=0(root) returned


```

(kali㉿kali)-[~/Desktop]
$ nmap -p 21 --script ftp-vsftpd-backdoor 192.168.56.103

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:17 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00088s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs: CVE:CVE-2011-2523 BID:48539
|     vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|       https://www.securityfocus.com/bid/48539
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
Nmap done: 1 IP address (1 host up) scanned in 3.74 seconds

```

Figure 7 – Targeted NSE check (ftp-vsftpd-backdoor) independently confirms the backdoor; uid=0(root)

False Positive Justification

Marked as a True Positive. The finding was not accepted from a version banner alone; it was confirmed by two independent NSE vulnerability checks (vuln script and the dedicated ftp-vsftpd-backdoor script), both returning uid=0(root) on the test command "id". This constitutes direct exploitation evidence.

Remediation

- Remove the backdoored vsftpd 2.3.4 build and upgrade to a clean vendor-supplied version (2.3.5 or later), verifying the source archive checksum before installation.
- Restrict or disable the FTP service if it is not required; block TCP/21 and TCP/6200 at the firewall.
- Map to NIST SP 800-53 SI-2 (Flaw Remediation).

Priority: Immediate – confirmed unauthenticated RCE as root with a public Metasploit module.

F-02: UnrealIRCD 3.2.8.1 Backdoor Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2010-2075
CWE	CWE-78 – OS Command Injection (embedded malicious code)
CVSS v3.1 Score	9.8 (Critical) – NVD legacy v2: 7.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.103) – IRC / TCP 6667
Tools Used	Nmap NSE (irc-unrealircd-backdoor), service version detection (-sV)
False Positive?	No – True Positive

Description

The IRC service runs UnrealIRCD, identified by Nmap service detection on TCP/6667. Between November 2009 and June 2010 the official UnrealIRCD 3.2.8.1 source tarball was trojaned, adding a backdoor in the DEBUG3_DOLOG_SYSTEM macro that executes any command passed to it. Metasploitable 2 ships this compromised build, allowing unauthenticated remote command execution.

Impact

An attacker can run arbitrary system commands on the host without authentication, typically achieving a shell and full system compromise. This leads to data theft, service disruption, and lateral movement – the same outcome as F-01 through a different service.

Evidence

```
(kali@kali) [~/Desktop]
$ nmap -p 6667 --script irc-unrealircd-backdoor 192.168.56.103

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:17 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00061s latency).

PORT      STATE SERVICE
6667/tcp  open  irc

Nmap done: 1 IP address (1 host up) scanned in 0.73 seconds
```

Figure 8 – Nmap identifies IRC service on TCP/6667; NSE irc-unrealircd-backdoor script confirms port accessible

```
(kali@kali) [~/Desktop]
$ nmap -sV 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:34 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0089s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SWORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  rsh          Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gmirregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCD
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.81 seconds
```

Figure 9 – Service scan (-sV) showing UnrealIRCD on TCP/6667; version cross-referenced with CVE-2010-2075

False Positive Justification

Marked as a True Positive. The Nmap -sV scan identifies the IRC service as "UnrealIRCd" on TCP/6667. Metasploitable 2 is a publicly documented intentionally vulnerable training platform that ships exclusively with UnrealIRCd 3.2.8.1 – the known backdoored build (CVE-2010-2075). The irc-unrealircd-backdoor NSE script confirmed port accessibility. The finding is consistent with the target OS and platform, ruling out false positive.

Remediation

- Re-download UnrealIRCd from the official site, verify the MD5/SHA checksums against the published hashes, and reinstall a clean version (or disable the service entirely if IRC is not required).
- Restrict access to TCP/6667 to trusted hosts only via firewall rules.
- Map to NIST SP 800-53 SI-2 (Flaw Remediation) and SI-7 (Software Integrity).

Priority: Immediate – unauthenticated RCE with a public Metasploit exploit module.

F-03: Samba "username map script" Command Execution (Critical)

Severity	Critical
CVE ID	CVE-2007-2447
CWE	CWE-78 – OS Command Injection
CVSS v3.1 Score	9.8 (Critical) – NVD legacy v2: 6.0
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.103) – SMB / TCP 139, 445
Tools Used	Nmap NSE (smb-os-discovery)
False Positive?	No – True Positive

Description

The host runs Samba 3.0.20-Debian, as confirmed by the smb-os-discovery NSE script. Samba versions 3.0.0 to 3.0.25rc3 fail to sanitise the username string before passing it to /bin/sh when the "username map script" option is in use. By supplying a username containing shell metacharacters, an attacker can execute arbitrary commands. Because the mapping happens before authentication, no valid credentials are required.

Impact

Unauthenticated remote command execution, generally as root, leading to full host compromise. SMB signing is also disabled on this host, weakening the service further and enabling relay attacks.

Evidence

```
(kali@kali)-[~/Desktop]
$ nmap --script smb-os-discovery.nse -p445 192.168.56.103

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:18 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00048s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-os-discovery: 1 host(s) completed (1 up), 1 undergoing SYN scan
| OS: Unix (Samba 3.0.20-Debian) 100% done, ETCP: 10:18:00:02:04:remot
| Computer name: metasploitable 100% done, because retransmission cap
| NetBIOS computer name:
| Domain name: localdomain 100% done, 100% done, 1 undergoing SYN scan
| FQDN: metasploitable.localdomain
| System time: 2026-06-07T10:18:07-04:00 100% done, 100% done, 1 remai
|_ 100% done, 100% done, 1 undergoing SYN scan
Nmap done: 1 IP address (1 host up) scanned in 0.83 seconds
```

Figure 10 – NSE smb-os-discovery confirms Samba 3.0.20-Debian on TCP/445, falling within the vulnerable version range (3.0.0–3.0.25rc3)

False Positive Justification

Marked as a True Positive. The smb-os-discovery NSE script independently confirms the Samba version as 3.0.20-Debian, which is within the documented vulnerable range for CVE-2007-2447 (3.0.0 to 3.0.25rc3). Version evidence alone is supported by the known Metasploitable 2 platform configuration.

Remediation

- Upgrade Samba to a supported, patched release (3.0.25 or later, or the current stable branch).

- If the "username map script" option is not required, remove it from smb.conf; additionally enable SMB message signing to prevent relay attacks.
- Restrict SMB access (TCP/139, 445) to trusted networks; map to NIST SP 800-53 SI-2 (Flaw Remediation).

Priority: Immediate – unauthenticated RCE with a public Metasploit module.

F-04: Java RMI Registry Insecure Default – Remote Code Execution (Critical)

Severity	Critical
CVE ID	N/A (configuration weakness; ref. Metasploit java_rmi_server)
CWE	CWE-94 – Code Injection
CVSS v3.1 Score	9.8 (Critical)
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
System / Port	Metasploitable 2 (192.168.56.103) – Java-RMI / TCP 1099
Tools Used	Nmap NSE (rmi-vuln-classloader)
False Positive?	No – True Positive

Description

A Java RMI registry is exposed on TCP/1099 in its default configuration. The default settings allow classes to be loaded from a remote URL, which an attacker can abuse to supply and execute arbitrary Java code on the server, achieving remote code execution without any authentication.

Impact

An unauthenticated attacker can execute arbitrary code on the server, leading to full system compromise. This provides yet another independent path to root on the target.

Evidence

```
(kali㉿kali)-[~/Desktop]
$ nmap --script rmi-vuln-classloader -p1099 192.168.56.103

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:18 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0018s latency).

PORT      STATE SERVICE
1099/tcp  open  rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|   RMI registry default configuration remote code execution vulnerability
|   State: VULNERABLE
|   Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds
```

Figure 11 – NSE rmi-vuln-classloader confirms Java RMI registry on TCP/1099 is VULNERABLE – "Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution"

False Positive Justification

Marked as a True Positive. The Nmap NSE rmi-vuln-classloader script directly probes the RMI registry and returns a VULNERABLE state with a detailed description of the insecure class-loading behaviour. The finding was not accepted from a version banner alone.

Remediation

- Disable remote class loading on the RMI registry (set the java.rmi.server.useCodebaseOnly property to true), or restrict the service to localhost / trusted hosts only.

- Run RMI services with a restrictive Java security policy; do not expose TCP/1099 to untrusted networks.
- Map to OWASP A05:2021 (Security Misconfiguration) and NIST SP 800-53 CM-6 (Configuration Settings).

Priority: Immediate – unauthenticated RCE confirmed by NSE, public exploit available.

F-05: OpenSSL CCS Injection (Man-in-the-Middle) (High)

Severity	High
CVE ID	CVE-2014-0224
CWE	CWE-300 – Channel Accessible by Non-Endpoint (MITM)
CVSS v3.1 Score	7.4 (High)
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N
System / Port	Metasploitable 2 (192.168.56.103) – PostgreSQL / TCP 5432 (SSL)
Tools Used	Nmap NSE (ssl-ccs-injection)
False Positive?	No – True Positive

Description

The SSL/TLS service on TCP/5432 (PostgreSQL) uses a vulnerable OpenSSL version that improperly handles ChangeCipherSpec (CCS) messages. An attacker positioned between client and server (man-in-the-middle) can force the use of a weak, zero-length master key, allowing the session to be decrypted or tampered with. This is known as the "CCS Injection" vulnerability.

Impact

If an attacker achieves a man-in-the-middle position, they can decrypt or modify supposedly encrypted communications, potentially exposing credentials or sensitive data in transit. Impact is lower than the RCE findings because successful exploitation requires an interception position rather than direct network access alone.

Evidence

```
(kali㉿kali)-[~/Desktop]
$ nmap --script ssl-ccs-injection -p5432 192.168.56.103

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-07 10:18 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00072s latency).

PORT      STATE SERVICE
5432/tcp  open  postgresql

| ssl-ccs-injection:
|   VULNERABLE:
|     SSL/TLS MITM vulnerability (CCS Injection)
|       State: VULNERABLE
|       Risk factor: High
|       OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
|       does not properly restrict processing of ChangeCipherSpec messages,
|       which allows man-in-the-middle attackers to trigger use of a zero
|       length master key in certain OpenSSL-to-OpenSSL communications, and
|       consequently hijack sessions or obtain sensitive information, via
|       a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
|   References:
|     http://www.cvedetails.com/cve/2014-0224
|     http://www.openssl.org/news/secadv_20140605.txt
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|_

Nmap done: 1 IP address (1 host up) scanned in 1.79 seconds
```

Figure 12 – NSE ssl-ccs-injection confirms VULNERABLE state on TCP/5432: "SSL/TLS MITM vulnerability (CCS Injection) – State: VULNERABLE, Risk factor: High"

False Positive Justification

Marked as a True Positive. The Nmap NSE ssl-ccs-injection script directly probes the TLS handshake on TCP/5432 and returns a VULNERABLE state with a detailed description matching CVE-2014-0224. The finding was not accepted from a version banner alone; it was confirmed by active script-based detection.

Remediation

- Upgrade OpenSSL to a fixed version (0.9.8za / 1.0.0m / 1.0.1h or later) on the host and restart all dependent services.
- Disable obsolete SSLv2/SSLv3 and weak cipher suites; enforce TLS 1.2 or higher.
- Map to NIST SP 800-53 SC-8 (Transmission Confidentiality and Integrity).

Priority: Short-term – high CVSS, but exploitation requires a man-in-the-middle position, so it ranks below the four unauthenticated RCE findings.

5. Remediation Summary & Priorities

Findings were prioritised by exploitability, real-world impact, and exposure rather than by CVSS score alone.

ID	Recommended Action	Severity	Priority
F-01	Upgrade / remove vsftpd; block TCP/21 & TCP/6200	Critical	Immediate
F-02	Reinstall clean UnrealIRCd; verify checksums; restrict port 6667	Critical	Immediate
F-03	Patch Samba; remove "username map script"; enable SMB signing	Critical	Immediate
F-04	Disable RMI remote class loading; restrict TCP/1099	Critical	Immediate
F-05	Upgrade OpenSSL; disable SSLv2/3 and weak ciphers	High	Short-term

5.1 Why CVSS Is Not the Only Factor

F-05 carries a High CVSS score (7.4) but is ranked below the four Critical RCE findings because it requires the attacker to first achieve a man-in-the-middle position on the network – a meaningful barrier that is not present in an external attack without prior access. By contrast, the four Critical findings are unauthenticated, network-reachable, and trivially exploitable with publicly available tools (Nmap NSE, Metasploit), so their real-world exploitability is far higher than their individual score differences might suggest.

Additionally, lower-scored hygiene issues observed during the scan (for example, SMB signing disabled on TCP/445 and anonymous FTP login allowed on TCP/21) can become dangerous when chained with other weaknesses, even though their individual scores are modest. Effective prioritisation therefore weighs exploitability and exposure alongside the raw CVSS number.

6. References

- NIST SP 800-115 – Technical Guide to Information Security Testing and Assessment. csrc.nist.gov
- OWASP Testing Guide v4; OWASP Top 10 A05:2021 – Security Misconfiguration. owasp.org
- CVE / NVD: CVE-2011-2523 (vsftpd), CVE-2010-2075 (UnrealIRCd), CVE-2007-2447 (Samba), CVE-2014-0224 (OpenSSL CCS). nvd.nist.gov / cve.org
- CWE: CWE-78 (OS Command Injection), CWE-94 (Code Injection), CWE-300 (MITM). cwe.mitre.org
- FIRST CVSS v3.1 Specification and Calculator. first.org/cvss
- Rapid7 Metasploit modules: vsftpd_234_backdoor, unreal_ircd_3281_backdoor, samba_usermap_script, java_rmi_server. metasploit.com
- Nmap NSE scripts: ftp-vsftpd-backdoor, irc-unrealircd-backdoor, smb-os-discovery, rmi-vuln-classloader, ssl-ccs-injection. nmap.org/nsedoc